

USDT0 · SECURITY REVIEW

USDT0

onesig usdt0.

A security review of onesig usdt0.

CLIENT
USDT0

PROJECT
onesig usdt0

AUDITORS
Guardian

AUDIT WINDOW
May 26 – May 28,
2025

FINAL REPORT
June 4, 2025

§ 00

Contents.

13 pages — overview, confidence ranking, scope, 4 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 4 findings	P. 08
§ 05	Disclaimer	P. 12
§ 06	About Guardian	P. 13

§ 01

Overview.

Guardian reviewed onesig usdt0 across a single review round. The final report includes 4 Informational findings.

AUDIT FIRM	REPOSITORY
Guardian	LayerZero-Labs/onesig
CLIENT	METHODOLOGY
USDT0	Smart contract · Manual · Main Review
PROJECT	MAIN REVIEW COMMIT
onesig usdt0	a5ed4b299da7
PREPARED BY	
Guardian	
AUDIT WINDOW	
May 26 – May 28, 2025	
FINAL REPORT	
June 4, 2025	

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	0	0	0	0	0
Medium	0	0	0	0	0
Low	0	0	0	0	0
Informational	4	0	4	0	0
All severities	4	0	4	0	0

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed onesig usdt0 in `LayerZero-Labs/onesig`.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW

Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
No files were recorded in scope.		

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
I-01	Verification Fails With Single Invalid Signature	DoS	INFORMATIONAL	ACKNOWLEDGED	p. 8
I-02	Double Hashing of Leaf Does Not Reduce Collision Probability as Intended	Warning	INFORMATIONAL	ACKNOWLEDGED	p. 9
I-03	Executors Pending Removal Can Still Execute Until Removal Nonce Is Reached	Warning	INFORMATIONAL	ACKNOWLEDGED	p. 10
I-04	Compatibility Across Networks	Warning	INFORMATIONAL	ACKNOWLEDGED	p. 11

INFORMATIONAL I-01

ACKNOWLEDGED

Verification Fails With Single Invalid Signature

CATEGORY	DoS
LOCATION	https://github.com/GuardianOrg/onesigonesig-usdt0-team1/blob/a5ed4b299da71aa17c7080e4c82a8314d37ce896/packages/onesig-evm/contracts/MultiSig.sol#L185
REVIEW	Main Review

DESCRIPTION

The `verifyNSignatures` function checks whether the provided signatures are sufficient to meet the multisig threshold. However, the function reverts if any of the provided signatures is invalid, even when the remaining valid signatures are enough to satisfy the threshold.

One of the signers in a multisig can intentionally provide an invalid signature, especially when the proposal conflicts with their personal interests. For example, in a 3-out-of-5 multisig, all five signers submit their offchain signatures to the executor, but one of them is deliberately invalid. When the executor attempts to execute the proposal, it reverts, despite the fact that the remaining four valid signatures should be sufficient. As a result, the executor must manually identify and remove the invalid signature, regenerate the calldata, and attempt execution again.

RECOMMENDATION

Instead of reverting on the first invalid signature, consider iterating through all provided signatures and counting the number of valid ones. Then, compare the count of valid signatures against the multisig threshold to determine whether the proposal is executable.

Alternatively, make sure the executor validates each signature off-chain before generating the calldata and ensures the function is called only with valid signatures.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL I-02

ACKNOWLEDGED

Double Hashing of Leaf Does Not Reduce Collision Probability as Intended

CATEGORY	Warning
LOCATION	onesig/packages/onesig-evm/contracts/OneSig.sol at a5ed4b299da71aa17c7080e4c82a8314d37ce896 · LayerZero-Labs/onesig
REVIEW	Main Review

DESCRIPTION

OneSig performs double hashing on the Merkle leaf [link](https://github.com/LayerZero-Labs/onesig/blob/a5ed4b299da71aa17c7080e4c82a8314d37ce896/packages/onesig-evm/contracts/OneSig.sol#L259-L270), presumably to reduce the probability of hash collisions, as recommended in a previous audit report. ([Page-4](https://github.com/LayerZero-Labs/onesig/blob/main/packages/onesig-evm/audits/OneSig_EVM-Ottersec-MAY_02_2025.pdf))

However, double hashing does not reduce the probability of collisions — in fact, it can slightly increase it. Consider this:

- If $H(a) \neq H(b)$, it's still possible that $H(H(a)) == H(H(b))$ due to a second-layer collision.
- If $H(a) == H(b)$, then $H(H(a)) == H(H(b))$ definitely holds.

Thus, applying a hash function multiple times introduces no additional collision resistance and may slightly worsen it.

That said, double hashing can be helpful against second preimage attacks if the leaf might be exactly 64 bytes. But this is better addressed using domain separation, prefixing, or explicit encoding, which are standard cryptographic best practices. Furthermore, there is no way for the leaf encoding to be 64 bytes for one-sig as the base encoded data is 49 bytes and the Call object stores 64 bytes plus the arbitrary data itself.

RECOMMENDATION

There is no immediate risk posed by the current double hashing, so no change is strictly required. However, be aware that double hashing does not reduce collision probability.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL I-03

ACKNOWLEDGED

Executors Pending Removal Can Still Execute Until Removal Nonce Is Reached

CATEGORY	Warning
LOCATION	https://github.com/LayerZero-Labs/onesig/blob/a5ed4b299da71aa17c7080e4c82a8314d37ce896/packages/onesig-evm/contracts/ExecutorStore.sol#L108-L109
REVIEW	Main Review

DESCRIPTION

OneSig introduces a feature enabling both permissioned and permissionless execution via executors, which can be added or removed using designated functions.

The intended security mechanism is to call `removeExecutor` when an executor is identified as malicious. However, a gap exists: once an executor is flagged for removal, it can still execute previously scheduled transactions until the removal transaction (based on nonce) is processed.

If the protocol attempts to submit a transaction with `nonce + 1` to bypass this window, the malicious executor could front-run by executing the previously scheduled `nonce + 1` transaction first — effectively grieving the removal attempt.

A similar parallel exists with `setExecutorAllowed`, where changing a flag from `true` to `false` does not immediately revoke the executor's ability to execute already queued transactions. A malicious executor could front-run the disabling call by executing transactions just before the update takes effect.

RECOMMENDATION

Be aware of this race condition. Even using front-run resistant RPCs may not guarantee protection, due to involvement of multi-chain scenarios where latency and ordering are less predictable.

If this scenario is considered a serious threat, consider introducing a separate transaction queue specifically for executors pending removal or permission revocation, to ensure immediate containment of their privileges.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-04**

ACKNOWLEDGED

Compatibility Across Networks

CATEGORY	Warning
LOCATION	Global
REVIEW	Main Review

DESCRIPTION

Some networks may be incompatible with the OneSig EVM implementation for various reasons. Firstly, the Solidity version used in the OneSig contracts includes a version higher than 0.8.20 which uses `PUSH0` as an opcode. Some networks such as Linea or Kava do not yet support `PUSH0` and may therefore be incompatible with the OneSig contract without compiling specifically for their EVM compatibility.

For example:

```
cast call --rpc-url <RPC> --create 0x5f5c
```

Produces `**Error:** server returned an error response: error code -32000: invalid opcode: PUSH0` for Linea and `**Error:** server returned an error response: error code -32000: rpc error: code = Internal desc = invalid opcode: PUSH0` for Kava.

Furthermore, certain networks may lack support for ECDSA which is necessary for the OneSig contract, though no popular networks with this behavior have been identified.

RECOMMENDATION

Be aware of these requirements for compatibility.

RESOLUTION

Status: Acknowledged.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.